



Sri Lanka Institute of Information Technology

Gap Analysis Report

Submitted by: Group ID_30

IE3102-Enterprise Standards for Information Security

	Name	Registration Number	Email
1	Prasad M.M.W	IT23252868	IT23252868@my.sliit.lk
2	Weerakumara K.D	IT23202436	IT23202436@my.sliit.lk
3	Kumarage T.D.S.D.	IT23292918	IT23292918@my.sliit.lk
4	Lahiru W.T	IT23253612	IT23253612@my.sliit.lk

Table of Contents

1. Introduction and Overview

2. Purpose and Objectives

3. Scope of ISMS Implementation

4. Consulting Team Roles and Responsibilities

4.1 Lead Consultant / Project Coordinator

4.2 Risk & Controls Analyst

4.3 ISMS Documentation Specialist

4.4 Compliance Advisor

4.5 Presentation & Stakeholder Engagement Lead

5. Gap Analysis Report

5.1 Introduction to Gap Analysis

5.1.1 Purpose of the Gap Analysis

5.1.2 Followed Methodology

5.2 Overview of Current Information Security Posture

5.2.1 Organizational Context and IT Environment

5.2.2 Existing Security Policies, Procedures, and Controls

5.2.3 Current Strengths and Limitations in InfoSec Management

5.3 Mapping to ISO/IEC 27001:2022 Requirements

5.3.1 Clause-by-Clause Assessment

5.3.2 Annex A Controls Assessment

5.3.3 Areas of Compliance and Non-Compliance

5.4 Summary of Findings

5.4.1 Identified Non-Conformities

5.4.2 Key Observations

5.4.3 Strengths

5.5 Initial Risk Register

5.5.1 Identified Assets, Threats and Vulnerabilities

5.5.2 Risk Ratings

5.5.3 Prioritization of Risks

5.6 Risk Treatment Recommendations

5.6.1 Proposed Treatment Strategies

5.6.2 A Recommended Controls for High Priority Risks

5.6.3 Relevance to DSM IT (Pvt) Ltd Business Objective

6. Conclusion

1.Introduction and Overview

The Gap Analysis Report for DSM IT (Pvt) Ltd has been developed to analyze the entity's current information security position against the requirements of ISO/IEC27001:2022. DSM IT (Pvt) Ltd is a leading IT solutions provider that offers software development, infrastructure support and cloud-based services. It operates in a heavily regulated industry where the confidentiality, integrity and availability of information is paramount to client trust and business continuity. The establishment of a firm Information Security Management System (ISMS) practice is a key strategic approach in this competing and risk-driven space.

The gap analysis is intended to provide a transparent, evidence-based understanding of where DSM IT (Pvt) Ltd currently lies in relation to international best practice and areas of strength, partial compliance and conformity. In addition to compliance to ISO27001 requirements, the gap analysis intends to identify non-conformities which represent items that need to be rectified rather quickly. Through this structured and documented approach, the report provides non-compliance and compliance items to assist the organization in focusing their resources accordingly and closing the gaps, so that preparation can begin for the implementation employee resilience and redirecting energy toward establishing certification to ISO/IEC 27001.

In order to accomplish this, the Consulting Team undertook a systematic methodology based on document review, stakeholder interviews, observational studies, and clause-by-clause mapping against the standard. The analysis provides not only a baseline against the requirements of ISO/IEC 27001 for DSM IT (Pvt) Ltd, but it also adds risk-based thinking methodology by considering the threats, vulnerabilities, and controls being used.

This report's outputs will enable you to develop your initial ISMS Core Documentation Pack, your initial risk register, and an overall Risk Treatment Plan. Ultimately, this gap analysis is a diagnostic and a strategic plan for DSM IT (Pvt) Ltd to use in meeting the demands of compliance, governance, and confidence in the protection of client data and organizational assets.

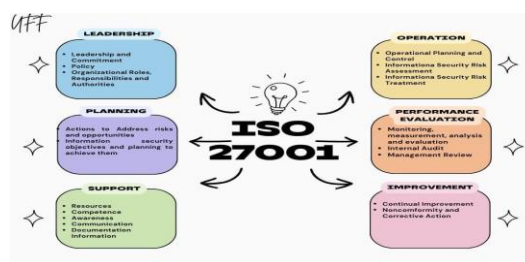
2. Purpose and Objectives

This task serves to support DSM IT (Pvt) Ltd in establishing the groundwork of an Information Security Management System (ISMS) as per ISO/IEC 27001:2022. And now, as an IT provider operating with the customer's most sensitive data and mission-critical systems, DSM IT has the responsibility to protect its own operations from unauthorized access, cybersecurity threats, or non-compliance. An ISMS, once implemented, will ensure that that organisation has a well-structured and internationally recognized way of securing their own information assets, as well as being able to demonstrate they are holding themselves to account to clients, regulators and partners.

The Sensormatic Solutions Approach Stage # 1: Gap Analysis The initial goal is to perform an extensive gap analysis that will analyze DSM IT's existing information security baseline. This is done by checking an existing process or system against the requirements of ISO 27001 and the controls from Annex A of ISO 27001, which identify whether the current process or system meets these. In turn, this will help the organization identify which areas need the most development and which can be used to their advantage when getting ready for certification.

Second is to compile the central ISMS documents, namely scope, information security policy, statement of applicability and risk treatment plan. These papers are intended to form the underpinning of DSM IT's ISMS in terms of strategy and operational guidelines. Furthermore, a risk register will be created to establish the relationship between key assets and threats, vulnerabilities and treatment options to promote a riskbased approach to security management.

The ultimate goal is to produce a board-level presentation and raise awareness of the facts and roadmap of, the benefits of carrying out ISO 27001. This will allow senior management to appreciate not only the risks, but also all the strategic advantages of an ISMS – such as regulatory compliance, customer confidence, operational resilience, and competitive advantage. Taken as a whole, the purpose and objectives will prepare DSM IT to aim for ISO 27001 certification and to create a culture of security enhancement.



3. Scope of the ISMS Implementation

The boundaries for the ISMS delineate what the ISMS is for i.e., the organization. It identifies the processes, systems and departments that are included in the ISMS, and also ensures that all attention is directed at protecting the most valuable assets. For DSM IT (Pvt) Ltd., the ISMS deployment will mainly cover IT solution Development, managed services and cloud infrastructure. Internal supports that are the business core processes and high value information.

The ISMS will be implemented on all business units that are responsible for the design development, implementation and support of IT solutions. This includes teams of software engineers, infrastructure services, information security operations, and the client support organization. Processes that are a natural part of an organization such as project management, incident response, data storage, and system administration are specifically addressed because of their direct relevance to delivering a service and gaining the trust of the customer.

Technically, the ISMS will apply to company networks, servers, cloud services, end user equipment and data centers that DSM IT operates or drives. Both on premises and cloud environments are in scope to provide consistent data protection across hybrid infrastructure. Subcontractors and third party service providers who process, transmit or store client information also fall within the ISMS framework as their activities affect the organization's risk position.

The general office facilities and personal devices that are not attached to corporate systems are out of scope, as they do not materially impact the confidentiality, integrity, or availability of the critical business data. Justification; and Documentation to keep the ISMS boundary clear of any interference.

By establishing that boundary, DSM IT (Pvt) Ltd is able to make its ISMS implementation full and efficient by focusing on the high-risk areas which need improvement and that are relevant to ISO/IEC 27001:2022 in particular requirements for continuous improvement and compliance-readiness.

4.Consulting Team Roles and Responsibilities



4.1 Lead Consultant / Project Coordinator

Lead Consultant/Project Coordinator at DSM IT (Pvt) Ltd is responsible in general for ISMS implementation simulation countermeasures. This person takes up the slack in project management and expectation management (of everybody – SOP as well as timing) DownieWorks to keep everything good quality, a good final rec that's well written and well presented to the board, things on time.

- **Project Management**

Lead Consultant decides on the Scope, Objectives and timeframes of the project following ISO/IEC 27001:2022. They allocate roles among the team members, keep an eye on the process, have to trouble shoot and micromanage any defects to ensure that the project is done on time. Lead Consultants guide the team on a course through responsible task management.

- **Quality Assurance of Deliverables**

An important remit of the Lead Consultant is to quality check all the deliverables – gap analysis, risk register, ISMS materials & presentations &etc, that it is accurate, it is complete, and that the works reflect what has been wanted. This is in compliance with iso 27001 guide, is compatible with another document or something may be a level of quality that is appropriate for executives. quality assurance dsm it (pvt) ltd is satisfied with the deliverables received from the consulting staff.

- **Board-Level Presentation and Recommendations**

The Lead AE is working on a board presentation, being given. That's the result of the gap analysis, risk and how you treat it, and with a small presentation of the strategic advantages of using ISO 27001. The complete ISMS and the wraparound of the results/report in language the board can read and understand are the 'value they added' and the 'work products' of the Lead Consultant.

Lead Consultant Facilitator: Support, supervision and lead on successful projects. With the strong and effective management and QA input, and also a strong link to senior management, the post is critical in leading DSM IT (Pvt) Ltd toward ISO 27001 and proactive information security resilience.

4.2 Risk & Controls Analyst

The Risk & Controls Analyst is a key player in the process of recognizing, monitoring, and mitigating risks in the ISMS implementation simulation DSM IT (Pvt) Ltd. This position is responsible for ensuring that the company's information security posture is measured, gaps are identified and adequate risk mitigation strategies are documented in compliance with ISO/IEC 27001:2022.

- **Conducting Gap Analysis**

The analyst starts by undertaking a gap analysis of DSM IT (Pvt) Ltd's existing security measures against those specified in ISO/IEC 27001:2022. This procedure will show which areas are in violation, what the current strengths are and how weak the system is. The results are used in setting risk management activities before ISMS is planned.

- **Developing the Risk Register**

From the gap analysis, the analyst develops a risk register documenting identified risks, threats and vulnerabilities, and affected assets. In risk management the risk is evaluated for probability and impact which helps the organization to rank the risks in order to rank the response to the risk. It is also a flexible tool to help make decisions and allocate resources.

- **Designing Risk Treatment Strategies**

The risks are then analyzed and ordered and the analyst produces the risk treatment plans. These can be as risk avoidance, reduction, sharing, or acceptance, depending on the requirements and the risk appetite of the organization. The analyst ensures treatment of plans align with, and provide support to DSM IT (Pvt) Ltd overall security objectives and controls (as per Annex A).

The Risk & Controls Analyst is responsible for DSM IT (Pvt) Ltd developing a clear view of our risks and implementing plans to handle them. This role is central to achieving ISO 27001 compliance and increasing the organization's resilience in information security through gap analysis, a structured risk register and treatment plans.

4.3 ISMS Documentation Specialist

The ISMS Documentation Specialist is responsible to prepare, compile and maintain all related documents (required documentation) for ISMS implementation in DSM IT (Pvt) Ltd. Responsibilities of the role: Ensuring all documentation is (to the ISO standard, see below, and) audit ready.

- **Drafting Core ISMS Documents**

One of the main roles is to produce the required ISMS documentation such as the Statement of Scope, Information Security Policy, SoA (Statement of Applicability) and Risk Treatment Plan. They could be seen as the backbone of the ISMS and present the organisation with an information security model. The specialist is certain each document formalizes and provides succinct verbal grounding for readers and management.

- **Ensuring ISO 27001 Alignment**

All ISMS Documentation Specialist-created documents shall be subject of the relevant clauses and controls of ISO/IEC 27001:2022. This could involve delving into papers around Annex A controls and comparing those to the organisation's own risk register and treatment plan. In doing so, the consultant ensures DSM IT (Pvt) Ltd's ISMS organization is aligned with global benchmarks and is able to withstand third-party scrutiny.

- **Managing Document Quality and Consistency**

The specialist is responsible for version control and defines document style and structure for ISMS papers. Great to ensure correctness (don't duplicate stuff) and great for professional looking end-product you can present to board. It also makes it easier to continually update documentation as risks evolve or new compliance mandates are created.

The ISMS Documentation Specialist will ensure that all ISMS documents are in order and in accordance with the ISO/IEC 27001:2022 standard. ISMS The foundation for the activity The foundation on which ISMS deployed successfully, DSM IT (Pvt) Ltd operates with confidence and securing by using a well defined, trusted and audit acceptable security model.

4.4 Compliance Advisor

Compliance Advisor – Role responsible to ensure the ISMS Implementation exercise for DSM IT (Pvt) Ltd is in compliance with all relevant laws, regulations and agreements. This role is fundamental in supporting alignment of ISO/IEC 27001:2022 controls with external compliance obligations as well as vetting the recommendations of our consulting teams for industry and legal fit.

- **Mapping Legal and Regulatory Obligations**

Recognizes preconditions from industry laws, regulations, and standards on DSM IT (Pvt) Ltd. This may be through global laws such as GDPR or through country-specific data protection regulations such as PDPA in Sri Lanka. Clearing these accountabilities The Compliance Advisor enables the ISMS to focus on international requirements as an well local to avoid unnecessary penalties.

- **Ensuring SoA Compliance**

The Compliance Officer assists in formulating the Statement of Applicability (SoA) through noting evidence of its control from Annex A is applicable to the risks and legal requirements. They confirm that where applicable, all of the selected controls are in use and are not omitted without proper reason. This will leave the SoA being not just accurate, but defensible during an audit.

- **Validating Recommendations and Risk Treatments**

The Compliance Advisor collaborates with the Risk & Controls Analyst and Lead Consultant, in reviewing risk treatment plan and recommendations to ensure alignment with compliance obligation. They give revert any holes, holes or inconsistency that rear, and in so doing guard DSM IT (Pvt) Ltd against acting unlawfully as well as against contract.

The Compliance Advisor provides a link between information security and regulatory compliance. Through the Visually representing the duties, accepting the SoA, and making suggestions that do not fall foul of the law, this role is facilitating further maturation of the

DSM IT (Pvt) Ltd ISMS and strengthening the trust between the regulators, clients, and stakeholder.

4.5 Presentation & Stakeholder Engagement Lead

The Presentation & Stakeholder Engagement Lead must translate the findings of the consulting team into a professional and compelling board level presentation to DSM IT (Pvt) Ltd. This is a role requiring well thought through visuals, streamlined key messages and roleplays to simulate stakeholder interaction for executive level buy in of ISMS implementation.

- **Developing the Board-Level Presentation**

The role's main responsibility will be to create a 10-12 slide PowerPoint presentation outlining the consulting project. It contains the executive summary, gap analysis results, roadmap for implementation, risks identified, selected strategies for risk treatment, strategic business benefits of ISO/IEC 27001:2022. The Lead assures in the presentation the display of the most important insights provided in an impactful and concise way, which is reviewed with the senior management.

- **Preparing Visuals and Roadmaps**

For complicated data so that it is easy for the clients to understand the Presentation Lead creates an information visualization through charts, graphs, infographics, and time-lines. This creates clarity together with further understanding on technical and risk interpretations for relevant stakeholders. A particular focus will be to develop a project plan which states phases, priorities and time scales relevant to the implementation of the ISMS within DSM IT (Pvt) Ltd.

- **Simulating Stakeholder Engagement and Q&A**

Beyond slide creation, it is also the head of the preparation for engagement with executives, in terms of anticipating the questions and concerns of the decision maker. In partnership with the team, the Presentation Lead scripts real-world Q&A scenarios and receives exposure to confident, well-structured responses. This will prepare your team of consultants to overcome obstacles and provide strong reasons when they go in front of the board during the simulation.

The Presentation & Stakeholder Engagement Lead effectively communicates the consulting team's work in a clear and impactful manner. Through developing a professional presentation, assembling visuals and controlling the C-level presence, this role

ensures the stakeholders have maximum confidence in the DSM IT (Pvt) Ltd's ISMS implementation journey.

5. Gap Analysis Report

5.1 Introduction to Gap Analysis

5.1.1 Purpose of the Gap Analysis

The gap analysis has the existence of ascertaining the current state of information security for DSM IT (Pvt) Ltd and determining the degree to which it meets the requirements of ISO/IEC 27001:2022." The analysis provides an official opinion of where the company is in relation to the standard and where the gaps, threats, or opportunities for improvement lie."Strength and non-conformity identification through gap analysis provide a basis in planning to roll out an Information Security Management System (ISMS). It then enables DSM IT (Pvt) Ltd to prioritize corrective measures, manage risk in reality, and create a roadmap to ISO 27001 certification and enhanced information security resiliency.

5.1.2 Followed Methodology

Step-by-step gap analysis was carried out wherein organization's current practices were aligned with clauses (4–10) and Annex A controls of ISO/IEC 27001:2022. Steps adopted in the process were:

1. Document Review – Policies, procedures, and technical settings of information security already in place were reviewed to ensure that requirements of the standard are met.
2. Interviews and Discussion – IT staff and stakeholders were interviewed in an attempt to further appreciate operational processes, issues, and ad hoc security measures in place.
3. Observation of Process – Standard information security processes such as access control and incident response were observed to determine reality of practice versus documented policy.
4. Gap Mapping – The identified practices were validated against ISO 27001 clauses and Annex A controls to identify conformance, partial implementation, or non-compliance areas.

5. Preliminary Risk Assessment – Assets, threats, and vulnerabilities were analyzed in order to assist in developing an initial risk register.

This method ensures findings to be evidence-based, comprehensive, and conformed to globally accepted best practice in information security management.

5.2 Overview of Current Information Security Posture

5.2.1 Organizational Context and IT Environment

DSM IT (Pvt) Ltd is a Software developing company offers wide range of services including Software development, IT Infrastructure support, Cloud based services etc. The company is competing in an environment where data privacy, system up-time, and regulatory compliance are critical to the public's trust in their product. Its IT ecosystem includes on-premises servers, cloud-based s ilion premises i d g e and a mix of enterprise applications and client web based offerings. Staff depend on digital communication, collaboration technology and remote access solutions – making information security a significant business priority.

5.2.2 Existing Security Policies, Procedures, and Controls

Currently DSM IT (Pvt) Ltd has put in place various basic information security controls in order to safeguard its business. These include:-

- Simple Access Controls: Utilization of usernames and passwords for system entry, but restricted use of multi-factor authentication.
- Antivirus and Firewalls: Implementation of endpoint protection and network firewalls to lower the attack surface of the organization from malware and external threats.
- Backup & Disaster Recovery: Regular backups of business critical systems, however inconsistent recovery testing.
- User Awareness Education: A loose user training which includes educating users about phishing and safe IT practices.
- Physical Security: Limited access to server rooms and secure housing for key hardware components.

But, these people-based controls are still in active use and no integration with a more formal ISMS exists. Policies and guidelines are in draft or ad-hoc state not consistently documented, reviewed and enforced.

5.2.3 Current Strengths and Limitations in InfoSec Management

DSM IT (Pvt) LTD does have some strengths such as a proactive IT culture, an understanding of cyber security risk and investment in technical controls (firewalls and backups). Additionally, the company is supported by a skilled work force that can use sophisticated controls technology as the needs arise.

On the other hand, there are imposed restrictions. Policies not formally documented or existing as per baseline ISO/IEC 27001:2022 standards. Risk control is weak and there is no integrated risk register or risk plan. Both accessibility to and active monitoring of incidents are limited, with reports produced primarily by hand rather than telemetry. Furthermore no systematic evaluation has been carried out with regard to compliance with external regulation and contractual obligations and there is the risk to the organization in terms of legal and reputation.

5.3 Mapping to ISO/IEC 27001:2022 Requirements

5.3.1 Clause-by-Clause Assessment (Clauses 4–10)

DSM IT (Pvt) Ltd was compared with the mandatory clauses of ISO/IEC 27001:2022. The findings state that some security fundamentals have been started by the company but it lacks a documented and formalized Information Security Management System (ISMS).

- Clause 4 – Organization Context: Internal and external context is understood but not formally documented or as per stakeholder expectations.
- Clause 5 – Leadership: Security activity is supported by senior management, yet organizational duties and roles are not formally documented, nor is there a formally documented information security policy.
- Clause 6 – Planning: The risk register or treatment plan is not formally documented by the organization. Information security goals are not formally established.
- Clause 7 – Support: There is awareness but in an ad hoc manner, without competency development processes, communication, and documentation.
- Clause 8 – Operation: Regular security practice is being implemented but not in the name of managed standard ISMS processes.
- Clause 9 – Performance Evaluation: No systematic management monitoring, auditing, or review has been carried out.
- Clause 10 – Improvement: Reactive correction of improvements rather than planned corrective action or ongoing improvement.

Clause	Requirement	Current Status at DSM IT (Pvt) Ltd
Clause 4: Context of the Organization	Identify internal/external issues, interested parties, and ISMS scope.	Context partially understood but not formally documented.
Clause 5: Leadership	Commitment from top management, InfoSec policy, roles and responsibilities.	Leadership supportive but lacks a documented security policy.
Clause 6: Planning	Risk assessment, risk treatment plan, InfoSec objectives.	No structured risk register or treatment plan exists.
Clause 7: Support	Resources, competence, awareness, communication, documentation.	Basic awareness sessions conducted, but no formal training or documentation system.
Clause 8: Operation	Implementing and controlling ISMS processes	Security activities exist but are informal, not process-driven.
Clause 9: Performance Evaluation	Monitoring, internal audit, management review.	No audit or review processes currently in place.
Clause 10: Improvement	Corrective actions, continual improvement.	Ad-hoc issue handling, no structured improvement mechanism.

5.3.2 Annex A Controls Assessment (A.5 to A.8)

Annex A controls provide technical and organizational security in good depth. DSM IT (Pvt) Ltd does attempt some early stages but remains considerably underdeveloped in formal compliance as a whole.

- A.5 – Organizational Controls: There are some draft security policies but not formally approved and rolled out.
- A.6 – People Controls: Unofficial worker awareness but absence thereof. No user or HR responsibilities-related security audits.
- A.7 – Physical Controls: Accessible from authorized persons but overall physical security is weak.
- A.8 – Technological Controls: Highly minimal controls like password protection and periodic backups but multi-factor authentication, encryption, and

automatic monitoring are not present.

Annex A Domain	Control Area	Current Practice
A.5: Organizational Controls	Policies, roles, compliance requirements.	Draft policies exist, but not formally documented or approved.
A.6: People Controls	User responsibilities, awareness, background checks.	Informal awareness provided, no structured user responsibilities or HR checks.
A.7: Physical Controls	Facility security, equipment protection.	Restricted access to server room; basic locks in place.
A.8: Technological Controls	Access control, backup, encryption, monitoring.	Passwords and backups in place, but MFA, encryption, and monitoring lacking.

5.3.3 Areas of Compliance and Non-Compliance

- Areas of Compliance / Strength
 - Basic access control (username and password).
 - Normal backup of data.
 - Locked access to the server room.
- Partial Compliance:
 - There are draft policies but not yet approved.
 - Patchy ad-hoc awareness.
 - There are technical controls in place but not as part of an ISMS.
- Non-Compliance:
 - There is no documentation of ISMS scope, risk register, and treatment plan.
 - There is no internal audit, monitoring, or improvement process.
 - No external legal or regulatory compliance mapping of.
 - No next-generation security controls (e.g., MFA, encryption, discovery automation) deployed.

5.4 Summary of Findings

Gap analysis on DSM IT (Pvt) Ltd The analysis on the gap on DSM IT private limited mentions some strength, partially aligned area & critical gaps multiply with ISO/IEC 27001:2022 requirements. This summary gives a brief overview of the organisation's current status related to information security, and indicates where there is room for improvement as part of the ISMS deployment.

5.4.1 Identified Non-Conformities

The gaps were identified with respect to the ISO 27001 clauses as follows.

- 5.4.1** Lack of an explicitly defined ISMS scope which is being formalised/recorded.
- 5.4.2** Lack of risk register and risk treatment plan in place.
- 5.4.3** No approved corporate information security policies and procedures.
- 5.4.4** There are no internal audits, monitoring or management review.
- 5.4.5** Lax adoption of Annex A controls, a notable lack of controls in multi-factor authentication, encryption and automated monitoring for example.
- 5.4.6** Lack of instrumentation of legal/regulatory/contractual requirements to ISMS controls.

5.4.2 Key Observations

A number of concerns to meet the ISO/IEC 27001 were identified:

- 5.4.7** Security groundwork is there, but is mostly ad hoc, rather than codified.
- 5.4.8** Employee-perception, non-routine and inconsistent, lack of training and awareness programs.
- 5.4.9** There are few incident reporting or management channels, and no formal escalation or documenting process.
- 5.4.10** Physical as well as technical control is in place but are not fully merged into an overall ISMS framework.
- 5.4.11** There are security processes that fly under the radar, and lack clear ownership and responsibility.

5.4.3 Strengths

However, despite the deficiencies, DSM IT (Pvt) Ltd shows some appreciable strengths in its current InfoSec position:

- 5.4.12 The services were locked down with basic access control mechanisms (username and password protection).
- 5.4.13 Proper data backup procedures are in place to protect against loss of critical information.
- 5.4.14 Only authorized personnel have physical access to server rooms.
- 5.4.15 The org has a highly skilled technical team who are able to do deep work on security.
- 5.4.16 Employees know there are security threats out there and it's growing so there is a base to build on for formal training programs.

5.5 Initial Risk Register

The first one is an IT risk register for DSM IT (Pvt) Ltd which lists their main assets, threats, associated vulnerabilities, and assesses the related risks by using the impact model. This register is the base for risk treatment strategies and relation between ISMS controls and ISO/IEC 27001:2022 standards.

5.5.1 Identified Assets, Threats and Vulnerabilities

The organization's critical assets and associated threats and vulnerabilities were evaluated as:

- IT services: systems and network administration, cloud and others
 - o Threats: Cyber-attacks, malware, unauthorized access, Poor access management, lack of multi-factor authentication, obsolete programs
- Applications and Software Solutions
 - o Threats: Software exploitation, data loss "We did not have [adequate] plans to increase the protection around our IT systems.
 - o Weaknesses: Incomplete patch management, Little security testing

- Sensitive Client Data
 - o Risks: Stolen Data, Inadvertent Release, Ransomware Submission
 - o Weaknesses: Low encryption level, inadequate policies for data handling
- Employee Devices and Endpoints
 - o Threats: Malware infection, phishing attacks
 - o Vulnerabilities: In-poor-password policy, not-monitoring-endpoint
- Tangible Assets (server room, office equipment).
 - o Threats: Theft, natural disasters
 - o Weakness: Limited control of physical processes and poor environment monitoring

5.5.2 Risk Ratings (Likelihood × Impact)

Every risk was judged by likelihood and impact:

- 5.5.1** High Risk: Probably will occur and would cause significant operational, financial or reputational harm.
- 5.5.2** Moderate Risk: Likely event with moderate impact on operations or security posture.
- 5.5.3** Low Risk: It is unlikely and would have minor impact if they did occur.

For example:

Unauthorized access of client data → High probability × High impact → High Risk

- Occasional minor downtime for system maintenance → Likelihood: Low x Impact: Medium → Risk: Low

5.5.3 Prioritization of Risks

Prioritized risks for DSM IT (Pvt) Ltd to allocate their resources efficiently:

- o High-Risk – Requires immediate action; very tight monitoring and control.

- Medium level risk items – Will mitigate and monitor the planned, probability, or impact reduction.
- Low: Routine practice to monitor by inspect, or periodically review, no immediate action is necessary.

This attention to priority is designed so the organisation can tackle risks in order of risk importance and will underpin both the Risk Treatment Plan and the ISMS strategy as a whole.

5.6 Risk Treatment Recommendations

Based upon the risk identification and the prioritization in the risk register - 1, the subsequent risk treatment options for DSM IT (Pvt) Ltd are proposed. The concepts will help minimise the potential risks, secure critical assets and be consistent with the business goals of the entity, meet the compliance requirements of ISO/IEC 27001:2022.

5.6.1 Proposed Treatment Strategies

Any of the four ways can address the mentioned type of interpolations.

- Avoid: Remove activities or processes that create a lot of risk for the organization.

Example: Stop using software not supported and possibly having security vulnerabilities.

- Reduce: Lower the risk according to its probability or loss.

Example: Use multi-factor authentication, encrypt sensitive data, and have endpoints automatically scanned.

- Transfer: Put the risk onto a third party, through measures like outsourcing or insurance.

Example: Store sensitive data on cloud service provider platforms who have strong security credentials.

- Accept: Accept low-level risks and track them with a wait-and-see attitude as long as they are within the risk tolerance level of the organization.

Example: Impacting only a small part of the system for scheduled maintenance.

5.6.2 A Recommended Controls for High Priority Risks

Annex A Controls proposed High risk items 6.2.1 Labelling 6.2.1.1 All unsound peas shall be derived from sound stock 6.2.1.2 An official certification label shall be attached to all consignments.

In order to adequately address High-priority risks, the following Annex A controls will need to be evaluated:

- A.5. 1 Information Security Policies Formalize and establish enterprise-wide security policies.
- A.6. 1 Security Policies Organisational Security Policy: Explicitly designate security responsibility.
- A.8. 1 Asset Management: Discover and index critical IT and data assets.
- A.9. 2 Access Control – use Multi factor Authentication, strong password policy, and role based access.
- A.12. 1 OpSec: Antivirus is a must, lockdown configurations, and leverage logging/monitoring.
- A.17. 1B(OPM 1 REV) Information Security Continuity Back Up, Disaster Recovery, and Business Continuity Develop backup, disaster recovery, and business continuity procedures.

5.6.3 Relevance to DSM IT (Pvt) Ltd Business Objective

Risk treatments proposed are rationalised to the organisational's strategic goals:

- Secure Client Information: Enhancing controls serves to establish trust and meet regulatory requirements.
- Strengthening Business Continuity: Risks are moderated, and minimized downtime and disruption are achieved.
- Support and Contribute to Business Growth: A developed ISMS lets the business to pursue new ventures and clients with confidence.
- Show Compliance with ISO 27001: Risk treatment to int'l standards will enhance credibility, market position.

By adopting these controls, DSM IT (Pvt) Ltd is able to diminish the exposure to information

security risks and to prevent threats to reasonable levels and take measures for acceptable controls consistent with cost effective controls and compliance with other requirements.

6. Conclusion

The gap analysis of DSM IT (Pvt) Ltd indicates that while the organization has implemented basic activities to help protect its information assets, such as user access controls, data backups, antivirus software, limiting physical access to server rooms, and other preliminary activities, the information security management system (ISMS) framework is significantly underdeveloped, especially when evaluated against ISO/IEC 27001:2022 requirements. Flaws in the ISMS take the form of: no clearly documented ISMS scope; insufficient risk register and risk treatment plan; security policies in draft or incomplete form; no formal mechanisms for implementing an internal audit; mechanisms for monitoring or continual improvement have not been considered; and some technical weaknesses - such as no multi-factor authentication, poor encryption practices, limited automated, monitoring - which create an increased risk exposure. Notwithstanding the aforementioned gaps, DSM IT (Pvt) Ltd enjoys the benefit of a capable and innovative technical workforce, a culture of awareness towards cybersecurity threats, and partial implementation of some security measures. Therefore, while DSM IT (Pvt) Ltd acknowledges its weaknesses, they now have the skills, knowledge, and culture to develop a more sophisticated ISMS, and start close the gaps identified. By rectifying identified non-conformities, including processes, policies, and procedures with a more structured approach; linking processes to ISO/IEC 27001:2022 clauses and Annex A controls; investigating the problem of risk and their management in a structured manner; and there is an opportunity for DSM IT (Pvt) Ltd to drastically improve their security posture. This will enhance regulatory compliance and business continuity, but it will also nurture client trust and aid strategic growth, as well as create a security-conscious culture in your business that could withstand the many evolving cyber threats.